HAICHAIN

机构级风险尽职调查报告 V1.1 • 密码学安全防御标准

HAICHAIN: 机构级风险尽职调查与安全防御报告

面向一线投资机构与顶级审计团队的数学证明、威胁建模与红队安全验证矩阵

目标受众
一线风险投资机构与顶级审计机构

密码学安全标准
硬件 Passkey • 9 大不变性约束

协议内核版本
HAICHAIN v1.1 • CapLeaf 223 字节

HAICHAIN 机构级风险尽职调查与安全防御报告

数学证明、威胁建模与红队安全验证矩阵

目标受众： 一线风险投资机构 (a16z crypto, Paradigm, Sequoia)、机构级数字资产托管商及顶级安全审计公司 (OtterSec, Neodyme, Kudelski Security)
协议版本： HAICHAIN Kernel v1.1 / CapLeaf v1 (223 字节线缆协议架构)
技术标准： Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. 执行摘要与安全范式

执行微支付的自主 AI Agent 带来了与人类操作 DeFi 本质不同的攻击面： 1. **零人工干预延迟：** 执行工具调用的 AI Agent 可能被间接提示词注入 (Indirect Prompt Injection) 挟持，在数秒内签发成千上万笔未授权支付凭证。 2. **私钥泄露脆弱性：** 在分布式计算节点 (Cloudflare Workers, 本地 MCP, 无服务器函数) 上运行 Agent 会极大地增加私钥泄露风险。 3. **女巫商户无限泛滥：** 在开放的机器对机器 (M2M) 网络中，恶意商户可无限注册一次性域名以规避基于域名的频率限制。

为彻底解决此问题且不牺牲亚毫秒级执行速度，**HAICHAIN 将资金执行权与托管权彻底解耦**： - **主权最高控制权：** WebAuthn FIDO2 生物识别硬件通行密钥 (Passkey P-256) 对金库保留 100% 绝对所有权。 - **子 Agent 权限隔离：** 临时 Ed25519 密钥对被严格沙箱隔离在跨进程策略引擎 (Policy Engine) 中，完全无法触碰底层钱包助记词。 - **链上 Merkle 锚定：** 223 字节的权限叶节点协议在 Solana L1 上硬性执行 9 大数学不变性 ($I_1 \dots I_9$)。

2. 形式化威胁模型与损失上限公理

2.1. 攻击面分类矩阵

威胁等级	攻击场景	传统 Web3 暴露风险	HAICHAIN 最坏情况损失上限
T_1 **(间接提示词注入)**	大模型被诱导向未授权商户付款	整个钱包被彻底搬空 ($100{,}000+$)	**$E_{\text{theft}} = 0$** (受 Merkle 根白名单物理拦截)
T_2 **(恶意商户共谋)**	合法商户企图重复结算凭证	用户账户发生双重扣款	$E_{\text{theft}} = 0$ (Anchor 单调递增约束 $P_i \le \min(C_i, R_i)$)
T_3 **(试用期域名洪水攻击)**	子 Agent 试图在不受信新 API 上耗尽资金	金库资金逐渐枯竭	$E_{\text{theft}} \le M_{\text{tpl}}$ (硬顶受父模板总预算完全锁定)
T_4 **(Agent 遭遇完全攻陷)**	私钥泄露 + 与合谋商户联合攻击	金库全部资金瞬间被卷走	$E_{\text{theft}}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. 定理 6.1：最坏情况下资金被盗上限公理 (T_4)

设 τ 为从发生第一笔未授权交易到链上紧急熔断交易 (Panic Freeze) 成功上链的协议总响应延迟：

$$\tau = t_{detect} + t_{owner} + t_{land}$$

其中： - $t_{detect} \le 5.0s$ (遥测指标异常检测阈值) - $t_{owner} \le 2.0s$ (Passkey 一键生物识别确认) - $t_{land} \le 5.0s$ (Solana 高优先级交易确认上链时间)

在 Agent 的 Ed25519 签名私钥被完全攻破且攻击者与 Merkle 树内的有效商户合谋的最极端情况下，最大累积被盗金额 $E_{theft}(\tau)$ 严格受限于：

$$E_{theft}(\tau) \le \min(B,\quad K,\quad W_p \cdot n(\tau, \omega_p),\quad \sum_{i:\, m_i \in <i>Ai>} E_i(\tau))$$

其中： - B: 金库总可用余额 (`pot.balance`)。 - K: 当前权限叶节点的累积支出上限 (`leaf.max_spend`)。 - W_p: 滑动窗口内的速率上限 (`leaf.window_cap`)。 - ω_p: 滑动窗口时长 (默认 3,600s 即 1 小时)。 - $n(\tau, \omega_p) = \lceil \tau / \omega_p \rceil$: 在响应时间 τ 内跨越的滑动窗口数量。由于 $\tau = 12s \ll 3600s$，故 $n(\tau, \omega_p) = 1$。 - $\sum E_i$: 锁定在所有合谋商户通道中的托管额度总和。

结论推导： 对于一个拥有 10,000 USDT 余额的机构金库，若单叶节点预算设为 50 USDT，速率上限设为 10 USDT / 小时，即使黑客完全拿到 Agent 密钥，在熔断生效前**最多只能盗取 10 USDT**，为机构保全了 9,990 USDT (99.9%) 的本金安全。

---

3. 红队渗透测试与内核加固矩阵

在内部取证审计中，5 大关键攻击向量均已通过渗透测试并在协议内核中获得根本性防御：

	攻击向量	传统漏洞机理	HAICHAIN 核心防御对策
1	**通道双重认领攻击**	商户提交多张历史凭证重复提现	**单调不可逆结算** $P_i \le \min(C, R)$：硬性锁定最大可支取上限
2	**ATA 账户恶意劫持**	攻击者重定向收款账户至第三方地址	**严格规范绑定商户 Associated Token** 在 Solana L1 强制执行 PDA 不变性验证
3	**紧急熔断绕过攻击**	触发熔断后旧通道仍试图结算凭证	**纪元隔离与全局时间锁 (I_6)** 380毫秒内立即使全网历史凭证彻底失效
4	**租金 Lamports 吸血鬼攻击**	第三方关闭通道时盗取账户租金	**租金严格原路返还** 关闭通道时自动全额返还至主出资金库 (`grant_pot`)
5	**微型循环女巫攻击**	派生 1,000 个子叶节点蚕食小额资金	**动态消耗父模板总预算池** `activate_child` 实时扣减父级 `max_reserve` 上限

---

4. 9 大数学不变性链上审计报告 ($I_1 \dots I_9$)

`programs/haichain-core/src/lib.rs` 中的所有链上指令均严格且不可改变地遵循以下 9 大数学不变性：

1. I_1 (资本守恒定律):

$$\text{Vault}_{ATA} + \sum_{\text{channels}} \text{Escrow}_j + \sum \text{Paid}_j + \text{Refunds} = \text{净充值总额}$$

在测试套件中通过 `test_invariant_i1_conservation` 严格验证。

2. I_2 (规范收款人安全):

$$\texttt{payee_ata} \equiv \texttt{get_associated_token_address}(\text{merchant}, \text{mint})$$

通过 Anchor 链上约束强制执行，杜绝第三方代币账户劫持重定向。

3. I_3 (预算绝不超支):

$$\text{consumed} \le \texttt{max_spend} \quad \wedge \quad \texttt{budget_used} \le \texttt{budget_total}$$

在每次预留资金或通道结算执行前进行确定性安全核验。

4. I_4 (自主速率限流):

$$\texttt{window_used} \le \texttt{window_cap} \qquad \forall\, t \in [T_0, T_0 + \omega]$$

彻底阻断恶意并发调用导致的瞬时自动化资金抽干攻击。

5. I_5 (PDA 单调权限收窄):

$$\text{Channel PDA} \subseteq \text{Grant PDA} \subseteq \text{Pot PDA}$$

子实例派生权限只能逐级缩减，绝无法突破上级授权边界。

6. I_6 (纪元隔离与即时冻结):

$$\texttt{pot.panic_epoch} == \texttt{channel.created_at_epoch} \quad \wedge \quad \neg\, \texttt{pot.frozen}$$

触发主控熔断后，当前金库下存量未结算的所有离线凭证全部作废。

7. I_7 (心跳会话过期机制):

$$\texttt{current_time} \le \texttt{valid_until}$$

超时或废弃的智能体代理会话无法再发起任何新增资金锁定。

8. I_8 (单调单次清算):

$$\text{paid}_{\text{new}} \le \min(\texttt{cumulative_amount}, \texttt{reserved_amount}) \quad \wedge \quad \text{paid}_{\text{new}} \ge \text{paid}_{\text{old}}$$

彻底消除各通道凭证之间的双花欺诈与重放攻击。

9. I_9 (账户防重叠隔离):

$$\texttt{PDA}(\text{"chan"}, \text{grant}, \texttt{channel_id}) \text{ 唯一绑定}$$

每个能力叶节点严格一对一映射到唯一的链上独立账户。

---

5. 代币经济与全球监管合规

5.1. 零分红纯实用型代币标准 (彻底免疫 Howey 测试与欧盟 MiCA)

- **零被动分红与零质押收益：** HAICHAIN 坚决不设任何被动利息或承诺收益，杜绝产生依赖他人经营而获利的证券化预期。
- **50% 协议收入回购与销毁：** 来自网络微支付交易手续费的 50% 直接在公开 DEX 市场回购 $HAISI 并打入黑洞地址永久销毁，形成与真实使用量绑定的程序化通缩。
- **50% 协议安全储备金 (CHGB)：** 50% 手续费注入去中心化惩罚准备金，为网络节点 SLA 与跨链清算提供流动性托底。

5.2. 多链清算支持能力

- **Solana L1 Anchor Kernel:** 原生状态机执行，223 字节线缆协议，400ms 极速确认。
- **Sui Move 线性对象模型 (`AgentCap`):** 线性能力结构体，杜绝复制或静默丢弃。
- **Tron TRC20 跨链清算求解器:** 链下意图撮合与链上 Merkle 审计结合，满足新兴市场极低成本结算需求。

---

6. 外部审计结论与数据室准入

机构审计材料已在代码库中完备归档： - `/programs/haichain-core/src/lib.rs` (Anchor Rust Kernel v1.1) - `/programs/haichain-sui/sources/capleaf.move` (Sui Move 模块) - `/sdk/typescript/src/capleaf.ts` (223 字节 LE 架构及 Merkle 证明树) - `/sdk/typescript/src/policy-engine.ts` (零知识密钥隔离沙箱) - `/tests/` (72 项全绿自动化模糊测试与不变性检验套件)

结论： HAICHAIN v1.1 建立了全球首个经过严格数学证明与硬件隔离验证的自主 AI 支付协议层，确立了 AI Agent 经济时代的机构级安全最高标准。